

Análisis y Planificación del Pentest para Aurora Market

Nombre completo: Veronica Fernandes

Fecha: 05-09-2026

1. Objetivos del Pentest

- **Objetivo 1:** Identificar y evaluar vulnerabilidades en la aplicación web de Aurora Market que puedan comprometer la confidencialidad de los datos de los clientes.
- **Objetivo 2:** Evaluar la resistencia de los mecanismos de pago e infraestructura transaccional para prevenir fraudes, robo de credenciales de pago o manipulación de pedidos.
- **Objetivo 3:** Proporcionar un informe ejecutivo y técnico con recomendaciones claras de remediación para elevar el nivel general de ciberseguridad y proteger la reputación de Aurora Market.

2. Alcance

Sí se evaluará (Dentro del alcance):

- Aplicación web principal de comercio electrónico <https://www.auroramarket.com>.
- API Rest / servicios web utilizados por el frontend para la gestión de usuarios, catálogo y pasarela de pago.
- Servidor web e infraestructura cloud asociada directamente con el entorno de pruebas/staging asignado.
- Formularios de inicio de sesión, registro, recuperación de contraseña y procesos de checkout.

Fuera del alcance:

- Ataques de Denegación de Servicio (DoS / DDoS) que puedan interrumpir la continuidad del negocio.

- Ingeniería social o phishing dirigido a empleados o clientes de Aurora Market.
- Entornos de producción críticos durante horarios de alta demanda sin coordinación previa.
- Seguridad física de los centros de datos u oficinas.

3. Autorización y Condiciones

Permisos requeridos:

- Carta de autorización formal firmada por la gerencia/dirección de Aurora Market (RoE - Rules of Engagement).
- Whitelisting de las direcciones IP de origen del equipo auditor en los Firewalls/WAF u otra tecnología protectiva.
- Creación de cuentas de prueba con diferentes roles de usuario (cliente estándar, administrador, etc.) en el entorno de staging.
- Persona de contacto técnico asignada para emergencias durante la ejecución de las pruebas.
- NDA firmado por ambas partes antes del inicio de las actividades

Condiciones acordadas:

- **Ventanas de ejecución:** Pruebas intensivas realizadas exclusivamente fuera del horario pico de la plataforma.
- **Notificación de vulnerabilidades críticas:** Notificación inmediata (menor a 2 horas) si se descubre una vulnerabilidad de severidad Crítica o Alta que ponga en riesgo inminente el sistema.
- **Manejo de datos sensibles:** Todos los datos de prueba capturados durante el pentest serán cifrados y destruidos tras la entrega del informe final.

4. Tipo de Pentest

- **Tipo de Pentest Elegido: Gray-Box (Caja Gris)**
- **Justificación de la Elección:** El enfoque Gray-Box simula la perspectiva de un atacante con conocimiento parcial o un usuario autenticado (como un cliente con cuenta o un empleado con privilegios limitados). Esto permite equilibrar la eficiencia del tiempo de auditoría con la cobertura de pruebas, garantizando la detección de fallos de escalación de privilegios y lógica de negocio sin gastar excesivo tiempo en el reconocimiento inicial a ciegas.

5. Planificación

- **Objetivos:** Definir las metas de evaluación técnica alineadas al negocio de e-commerce de Aurora Market.
- **Alcance:** Delimitar con precisión los activos, dominios e IP objeto de la auditoría.
- **Permisos y Condiciones:** Formalizar la documentación legal (NDA, autorización explícita) y canales de comunicación.
- **Metodología a utilizar:** Aplicar estándares reconocidos como OWASP Testing Guide (OTGv4) para aplicaciones web.
- **Recopilación de información previa:** Obtener documentación de arquitectura básica, endpoints de API clave y credenciales de prueba.
- **Recursos necesarios:** Herramientas especializadas (Burp Suite, Nmap, Metasploit), infraestructura de pruebas aislada e IP dedicada.
- **Programación del Pentest:** Establecer un cronograma claro detallando fechas para cada fase (Reconocimiento, Explotación, Reporte).

6. Fases del Pentest

1. Reconocimiento:

- Mapeo de la infraestructura web, descubrimiento de subdominios, tecnologías utilizadas (CMS, frameworks, servidor web) y enumeración de endpoints públicos mediante herramientas como Nmap.

2. Análisis de Vulnerabilidades:

- Escaneo automatizado y análisis manual estructurado buscando fallos de configuración, versiones desactualizadas y principales vulnerabilidades del top 10 de OWASP (inyecciones, CSRF, IDOR).

3. Explotación:

- Verificación manual de las vulnerabilidades detectadas mediante la ejecución controlada de exploits para confirmar su viabilidad y evaluar el impacto real sin causar caídas en el servicio.

4. Post-Explotación:

- Determinación del nivel de acceso alcanzado, intento de escalada de privilegios dentro de la aplicación y análisis del movimiento lateral potencial o acceso a datos sensibles.

5. Informe:

- Documentación detallada con un resumen ejecutivo para la gerencia y un apartado técnico detallando evidencias, impacto, vector de ataque y recomendaciones paso a paso para la remediación.

7. Investigación

- **Metodología elegida: OWASP Web Security Testing Guide (WSTG)**
- **Justificación:** La metodología OWASP WSTG es el estándar de la industria específicamente diseñado tanto para aplicaciones web como e-commerce. Proporciona una guía exhaustiva y estructurada de controles de seguridad a probar (autenticación, gestión de sesiones, validación de entradas, lógica de negocio y pagos), lo que garantiza que no se pase por alto ningún vector de ataque común que pudiera poner en riesgo la tienda Aurora Market. La sección de Lógica de Negocio WSTG-BUSN está especialmente diseñada para detectar fraudes en carritos de compra y pasarelas de pago. Cada ID de prueba en WSTG (por ejemplo, WSTG-INJV-05 para SQLi) viene acompañado del impacto esperado y las recomendaciones exactas de remediación para los desarrolladores.

